XYZ **Technology Services**

Mandatory Information Security Management System (ISMS)

Procedures

Document No: XYZ -TS-IS-PR-002

Classification: Internal

Owner: Chief Digital Officer (CDO)

Effective Date: 15-Sep-2021

CS5292 W6 · D05 · sanitised for teaching

Document History:

Release Date	Revision No	Author(s)	Description	Reviewed & Approved By	Next review date
15-Sep-2021	1.0	ISO	Approved Document	ISMC	Sep-2022
20-Sep-2022	1.0	ISO	Approved Document	ISMC	Sep-2023
05-Sep-2023	1.0	ISO	Approved Document	ISMC	Sep-2024
15-February	1.1	ISO	Amendments to the management committee meeting frequency	ISMC	Sep-2024
01-Mar-2025	1.2	ISO	ISO 27001:2022 Version Transition	ISMC	March-2026

CS5292 W6 · D05 · sanitised for teaching

Table of Contents

1. Purpose and Objectives 6
2. Distribution 6
3. Scope 6
4. Procedure for control of documents and records 6
4.1. Scope 6
4.2. Definitions 7
4.3. Procedure 7
4.3.1. Procedure for control of documented information 7
4.3.1.1. Issue and Control of documents of internal origin 7
4.3.1.2. Document Numbering 8
4.3.1.3. Version Controlling Guideline 9
4.3.1.4. Published Standards 10
4.3.1.5. Document and data changes 10
4.3.1.6. Document Review Process 11
4.3.1.7. Responsibility and Authority 11
4.3.1.7.1. Process Owner (PO)/ Department Head 11
4.3.1.7.2. XYZ-TS Governance Team 11
4.3.1.7.3. Head of IT Governance 11
4.3.1.7.4. CDO 12
4.3.1.7.5. Policy Custodian: 12
4.3.2. Control of Records 12
4.3.2.1. Generation 12
4.3.2.2. Contents of records 13
5. Procedure for conducting ISMS internal audits 13
5.1. Scope 13
5.2. Inputs to Internal Audits 13
5.3. Outputs of Internal Audits 14
5.4. Records 14
5.5. Process Interfaces 14
5.6. Process Flow of Internal ISMS Audit 14
5.7. Categories of Audit Findings 15
5.8. Closure of Findings 16

XYZ | Confidential - External

CS5292 W6 · D05 · sanitised for teaching

5.9. Collecting and Storing of Internal Audit Records 16
5.10. Follow up Audit 16
6. Procedure for management review of ISMS 16
6.1. Scope 16
6.2. Responsibility 16
6.3. Procedure 17
6.3.1. Procedure for Management Review 17
6.3.2. Review Meetings 18
7. Procedure for Nonconformity and Corrective Actions 19
7.1. Scope 19
7.2. Responsibility 19
7.3. Procedure 19
7.3.1. Corrective action 19
7.3.1.1. Identifying Nonconformities 20
7.3.1.2. Determining the causes of nonconformities 20
7.3.1.3. Determining, evaluating, and implementing the corrective actions needed 21
7.3.1.4. Recording the results of corrective actions taken 21
7.3.1.5. Review of Corrective actions proposed and implemented 21
7.3.1.6. Identifying the potential nonconformities 21
7.3.1.7. Evaluation of potential nonconformities 21
7.3.1.8. Determining and implementing actions to prevent potential nonconformities 22
7.3.1.9. Recording results of actions taken 22
7.3.1.10. Reviewing of the effectiveness of the actions Taken 23
8. Procedure for measurement of the effectiveness of ISMS controls 24
8.1. Scope 22
8.2. Responsibility 22
8.3. Procedure 23
8.3.1. Data collection 23
8.3.2. Information Security Dashboard 23
8.3.2.1. Defining the Matrices 23
8.3.2.2. Measuring the Matrices 24
8.3.2.3. Reviewing the Matrices Results 24
9. Latest Version of This Document 24

XYZ | Confidential - External
CS5292 W6 · D05 · sanitised for teaching

10. Key Roles & Responsibility 25

11. Compliance and Disciplinary Action 25

12. Reference Documents 25

CS5292 W6 · D05 · sanitised for teaching

1. Purpose and Objectives

The purpose of this document is to set out the process of the implementation of ISO/IEC 27001:2022 standard requirements.

2. Review

Policies, Procedures, Guidelines, and Standards contained in this policy will be reviewed annually or whenever a significant change arises applicable to this policy of XYZ-TS.

3. Distribution

This is an internal document and should only be shared with employees at XYZ -Technology Services (hereafter referred to as "XYZ-TS") and intended parties determined by the Information Security Officer (ISO).

4. Scope

The procedures included in this document apply to the XYZ-TS ISMS scope stated in XYZ-TS ***ISMS Scope*** (XYZ-TS-IS-MN-001).

5. Procedure for control of documents and records

5.1. Scope

The purpose of this process is to:

- Ensure that all documents and data related to the ISMS and other related documents specified under "4.2. Definitions" are reviewed and approved by those authorized to do so, that these are available at the appropriate locations for use, and that documents are numbered systematically. The scope covers all documents and data, including changes (new items and revisions) and documents of external origin.
- Define identification, collection, indexing, filing, storage, maintenance, and disposition of ISMS records and also identify methods that provide tractability and ease of access to ISMS records.

This procedure is in line with the XYZ-TS ***Information Security Management System Manual*** (XYZTS-***IS-MN-001)*** and adheres to the mentioned ISO/IEC 27001:2022 clause:

XYZ | Confidential - External

CS5292 W6 · D05 · sanitised for teaching

- 7.5 – Documented information

5.2. Definitions

Document definitions:

Level 1 documents	Information Security Management System Manual and Policies
Level 2 documents	Processes or Procedures
Level 3 documents	Other Linked Documents to Processes or Procedures, such as Templates of Forms, Registers, Applications, and Guidelines.
Master Documents Soft copy	All original copies of the ISMS manual, Processes, Work Instructions, and Forms/ Templates are Uploaded to the Information Security (IS) document library in SharePoint Portal.

Document and data changes to level 1 and 2 documents

Revision - Replacement of page(s) if any amendments affect the contents of the whole document apart from punctual, formatting, and grammatical corrections.

Document and data changes to level 3 documents

Revision - Replacement of the entire document if any amendments affect the contents of the whole document apart from punctual, formatting, and grammatical corrections.

5.3. Procedure

5.3.1. Procedure for control of documented information

5.3.1.1. Issue and Control of documents of internal origin

- Once a document is prepared, a unique identification number is assigned as per the document numbering system specified in Section 4.3.1.2 by the Information Security Officer (ISO).
- The document prepared shall be reviewed and approved by the ISO unless special authorization has been specified, such as ISMC.

XYZ | Confidential - External

CS5292 W6 · D05 · sanitised for teaching

- All relevant documents are uploaded in PDF format to the SharePoint shared folder.
- Only ISO and IT Governance (IS) team members shall have read and write access to change any document in the SharePoint Shared folder.
- Read-only access rights to the Master Documents soft copies are granted as below:
    - All IT Users - Level 1, 2, and 3 documents; and
    - All staff - Level 1 (Acceptable Usage Policy) & 3 (relevant forms) documents.
- All master soft copies of level 1 and level 2 documents shall be in the ISMS Document shared location, and any printout taken but not having stamped the documentation classification in the document will be "uncontrolled" copies.
- ISO ensures that all obsolete documents retained for knowledge preservation and/or legal purposes are stored in an archive folder.
- Information Security System Documents shall contain version control, including the following:
    - Identification of the documents;
    - Description / Subject of the document;
    - Signature of approval; and
    - Revision status.
- All copies issued and controlled shall be marked as per the information classification in the XYZ-TS ***Information Security Management System Policy*** (XYZ-TS-IS-MN-001).

5.3.1.2. Document Numbering

- The format for document number shall be XYZ-TS-<Function name>-<Document type><sequence no.> <version>
- Function Name (Department) will have a three-letter code as follows:

GOV for Governance Team,

SYS for Systems Team,

IDC for iDC Team,

SOC for SOC Team,

NOC for NOC Team,

SUP for Support Team,

CLO for Cloud Team,

SOU for IT Sourcing Team,

XYZ | Confidential - External

CS5292 W6 · D05 · sanitised for teaching

PMO for PMO

- Document type will have a two-letter code as follows:
  - PO – for policies;
  - PR – for processes/procedures;
  - FM – for Forms;
  - GD – for guidelines;
  - MN – for manuals; and
  - RG – for registers.

Example:

" XYZ-TS-IS-PO-001" - here, 'PO' stands for Policy, 'IS' stands for short acronym of Information System, 001 for the first document under this category.

"XYZ-TS-IS-PR-001" – here, 'PR' stands for Procedure and 001 for being the first procedure in the IT Division on information security.

5.3.1.3. Version Controlling Guideline

- Version numbers:
  - The author of the document will ensure the current version number is identified on the first page and, when possible, is incorporated into the footer of the document and appears on every succeeding page.
- Draft document version number
  - The first draft of a document will be Version 0.1 and
  - Subsequent drafts will increase by "0.1" in the version number, e.g., 0.2, 0.3, 0.4 …0.9, 0.10, and 0.11.
- Final document version number and effective date
  - The author will deem a document as final after all reviewers have provided final comments and the comments have been addressed;
  - The first final version of a document will be Version 1.0. Include the effective date when the document becomes final; and
  - Subsequent final documents will have an increase of "1.0" in the version number (1.0, 2.0, etc.).

XYZ | Confidential - External

CS5292 W6 · D05 · sanitised for teaching

- Final documents undergoing revisions
    - Final documents undergoing revisions will be Version X.1 for the first version of the revisions. While the document is under review, subsequent draft versions will increase by "0.1", e.g., 1.1, 1.2, 1.3, etc. When the revised document is deemed final, the version will increase by "1.0" over the version being revised, e.g., the draft 1.3 will become a final 2.0.
- Documenting substantive changes
    - A list of changes from the previous draft or final documents will be kept. The list will be cumulative and identify the changes from the preceding document versions. This will be included in the second page of the document.

5.3.1.4. Published Standards

ISO maintains and keeps updated current copies of standards and specification related to Information Security Management System and controlled copies of related standards are issued to respective users.

ISO maintains the issue control through interaction with Standards provider to ensure that the Standards are updated.

5.3.1.5. Document and data changes

- Requests for amendments shall be first reviewed by concerned Department Head before they are taken up for approval by ISO.
- Any changes relevant to document or data should be forwarded through the Department Head.
- When doing a change, change proposer should refer the latest source document & propose the required changes.
- ISO shall then change the revision number by increasing the current number by one, this together with reissued date is indicated in the documents. (If required as per the definition of Revision).
- The revised document will be uploaded to IS library and subsequently taken to the implementation, whilst recalling the obsolete documents from all locations or shall be labeled as "retained copy" in the document where applicable. The obsolete documents or data shall be suitably disposed to avoid inadvertent use.
- It is the responsibility of every personnel to update their copies and destroy the previous obsolete documents to avoid inadvertent use of obsolete documents. Mode of disposal of documents and records are done as per disposal procedure established within the ISMS.

XYZ | Confidential - External

CS5292 W6 · D05 · sanitised for teaching

5.3.1.6. Document Review Process

- An annual review of the documents shall be performed by ISO in order to ensure compliance to this procedure and necessary actions will be taken to rectify any deviations to the procedure.
- Also, non-routine reviews shall occur if any significant change arises in documentation.

5.3.1.7. Responsibility and Authority

- Change Request – Business Process Owner/ Department Head
- Recommendation – XYZ-TS Governance Team
- Validation – Head of IT Governance
- Approval – CDO
- Implementation – XYZ-TS Governance Team
- As per the latest version of the XYZ-TS ***Information Security Management System Manual*** (XYZ-***TS-IS-MN-001).***

5.3.1.7.1. Process Owner (PO)/ Department Head

- The Process owner/ Department Head/ ISO is responsible for identifying any policy alterations deemed appropriate. Whenever a policy alteration is required, the relevant policy owner should be informed.
- The Process owner/Department Head/ ISO should submit the policy alteration requisition to the XYZ-TS Governance Team with a business/ security / legislative justification as to why the change is needed.

5.3.1.7.2. XYZ-TS Governance Team

- XYZ-TS Governance Team shall initiate the discussion regarding the policy alteration requisition.

5.3.1.7.3. Head of IT Governance

- The head of IT Governance should consider all possible pros and cons and reach a final decision which should be endorsed by all the affected process owners as well as the CDO. The CDO may appoint a special committee for this purpose.

XYZ | Confidential - External

CS5292 W6 · D05 · sanitised for teaching

5.3.1.7.4. CDO

- CDO should take a final decision on the proposed policy alterations and may propose amendments to the policy.

5.3.1.7.5. Policy Custodian:

- Make the alterations as directed by the Head of IT Governance and submit the new version of the policy as a draft to the Head of IT Governance/ CDO for their approval.
- Once the Policy is approved by the CDO, the policy change must be implemented as per the new policy. This may involve changes to IT systems, processes, etc.

5.3.2. Control of Records

5.3.2.1. Generation

- Information records are generated at the places where it is necessary to provide objective evidence and ensure the following:
    - All security incidents.
    - Evidence of implementing policy and procedures.
    - Implementation of security objectives and targets.
    - Security Systems are functioning as per risk assessment; and
    - Corrective and preventive actions are implemented and are effective.
- IS Records are identified in key processes of units and the custody or responsibility of maintenance is under the owner of a particular process or Department in charge.
- The owner shall identify all quality records by a unique identification number as mentioned in the document numbering section (4.3.1.2) in the process for Control of Documents.
- Custodians of IS Records shall ensure that records filled are legible and filed properly to facilitate easy access.
- Once the IS Records are completed, the Custodian of these records shall use the archiving method for the particular records (filing with document number, System storage, etc.) which will be traceable and retrievable.
- SharePoint is recommended to store IS records.

XYZ | Confidential - External

CS5292 W6 · D05 · sanitised for teaching

- Disposition of IS Records is determined by the owner or custodian as per the business requirements as well as regulatory and legal requirements.
- At the end of the retention period, the relevant department custodians shall have them disposed of.
- IS Records shall be retrieved only with the approval of the custodian, Senior Management, or ISO.
- Any person in need of an IS record shall request it from the custodian of the record/ISO with approval or justifiable reasons.
- Custodian shall issue the requested IS record, if considered appropriate, and is responsible for timely retaining of record.

5.3.2.2. Contents of records

- The list of information security records contains the following:
    - Records description;
    - Location of the record;
    - Period of retention;
    - Identification; and
    - Name of the controller/holder.

6. Procedure for conducting ISMS internal audits

6.1. Scope

- This procedure applies to the Information Security Management System to determine its effectiveness and adequacy as expected. This procedure is in line with the XYZ-TS Information Security Management System Manual (XYZ-TS-IS-MN-001) and adheres to below mentioned ISO/IEC 27001:2022 Clause:
    - 9.2 – Internal Audits

6.2. Inputs to Internal Audits

- Internal ISMS Audit Schedule.
- Defined ISMS Documentation.
- Previous Internal/External Audit Findings.
- Inputs provided by an incident/ stakeholder/ Minutes of Management Review meetings.

XYZ | Confidential - External

CS5292 W6 · D05 · sanitised for teaching

6.3. Outputs of Internal Audits

- Implementation of corrective and preventive actions for identified findings.

6.4. Records

- Internal ISMS Audit Schedule.
- Internal ISMS Audit Summary Report.
- Evidence for Audit Findings Closure.

6.5. Process Interfaces

- Management Review Meeting.

6.6. Process Flow of Internal ISMS Audit

- Internal ISMS Audit Cycle is defined to be conducted annually.
- Prepare the tentative Internal ISMS Audit Program for the upcoming cycle (if outsourced ISO requires to obtain the audit schedule from the outsourced vendor).
- Review the audit scheduled by ISO and finalize the schedule.
- Circulate the audit schedule for Auditees and respective department heads by ISMS Auditor – at least one week prior to starting the audit.
- Conducting Internal Audits by ISMS Audit team*.
- Assigned auditors will conduct the internal audits objectively and impartially and within the stipulated time frame as planned in the audit schedule.
- Auditors shall not audit their own work.
- Conduct the closing meeting discussing the audit findings with Management Representative (MR) and respective auditees/ department heads.
- Submission of final audit report (list of findings).
- ISO to assign and circulate audit finding to department heads for identification of resolution.
- Department heads/ Auditees to submit root cause, correction, corrective actions and target dates for the assigned findings.

XYZ | Confidential - External

CS5292 W6 · D05 · sanitised for teaching

- ISO to evaluate the suitability of the submitted root cause, corrections, corrective actions and target dates to submit the same to internal ISMS auditors (if outsourced then to the outsourced vendor).
- ISMS Auditor to obtain and collate the evidence of implementation of committed corrective actions based on target dates.
- ISMS Auditor to submit the evidence on a fortnightly basis to ISO for review and approval.
- ISO to review collated evidence by ISMS Auditor for suitability/effectiveness and revert with approval.
- Submit the closure of findings with ISO approved evidence to the ISMS Audit team (if outsourced then to the outsourced vendor).
- Escalate risks, delay in deliveries and ineffective closure of findings or repeat findings to management as and when required/ in Management Review Meetings.

6.7. Categories of Audit Findings

- Non-Conformities are non-fulfillment of a specific requirement and requirements can come from many sources adopted by the origination.
- E.g. requirements specified in ISO/IEC 27001:2022 standard, internal requirements, applicable regulations, or customer requirements.

Major Nonconformance:

- The absence of, or the failure to implement and maintain, one or more management system elements, or a situation which would, based on the available objective evidence, raise significant doubt of the management to achieve:
    - The policy, objectives, or public commitments of the organization;
    - Compliance with the applicable regulatory requirements;
    - Conformance to applicable customer requirements; and
    - Conformance with the audit criteria deliverables.

Minor Nonconformance:

- A finding indicative of a weakness in the implemented and maintained system, which has not significantly impacted the capability of the management system or put at risk the system deliverables but needs to be addressed to ensure the future capability of the system.

Observation:

XYZ | Confidential - External

CS5292 W6 · D05 · sanitised for teaching

- A statement of fact that doesn't rise to the level of a nonconformity (no objective evidence of nonconformity, doesn't require a corrective action) but which, if left alone, could result in a future audit finding.

Opportunity for Improvement (OFI):

- A situation or condition of a management system that may be weak, cumbersome, redundant, overly complex, or in some other manner, may, in the opinion of the auditor, offer an opportunity for an organization to improve its current status. These OFIs do not require any action on the part of the organization; however, the organization should give them serious consideration in view of the auditor's knowledge and exposure to similar systems. An OFI may be an improvement to the management system or could prevent future problems.

6.8. Closure of Findings

- Auditee shall provide an acceptable remediation plan with an agreed time plan to close major and minor nonconformities within one month of the internal audit completion. The plan would be sufficient to close the audit findings.
- The implementation of the remediation plan will be checked exclusively at the next ISMS internal audit.

6.9. Collecting and Storing of Internal Audit Records

- ISO is responsible to upload the internal audit report to Compliance Team – Shared Folder immediately after receiving the report.
- All the audit evidence shall also be uploaded to Compliance Team – Shared Folder, marking clear reference to the findings.

6.10. Follow up Audit

- ISMS auditor shall close all the previous internal audit findings at the current internal audit cycle after verifying the correction and corrective action taken by the organization.

7. Procedure for management review of ISMS

7.1. Scope

- This procedure is in line with the XYZ-TS Information Security Management System Manual (XYZIS-MN-XXX) and adheres to below mentioned ISO/IEC 27001:2022 Clause:
    - 9.3 – Management review of ISMS

7.2. Responsibility

- ISMC Members.

XYZ | Confidential - External

CS5292 W6 · D05 · sanitised for teaching

- ISMS Audit Team

7.3. Procedure

7.3.1. Procedure for Management Review

Activity	Responsibility / Authority	Record Name & Number
Review Following inputs / matters to be considered for review of ISMS: a) The status of actions from previous management reviews; b) Changes in external and internal issues that are relevant to the ISMS; c) Feedback on the information security performance, including trends in: • Nonconformities and correctives actions; • Monitoring and measurement results; • Audits results; and • Fulfilment of information security objectives. d) Feedback from interested parties;	ISMC	MRM Agenda Note
Activity	**Responsibility / Authority**	**Record Name & Number**
e) Results of risk assessment and status of risk treatment plan; and f) Opportunities for continual improvement.		

XYZ | Confidential - External

CS5292 W6 · D05 · sanitised for teaching

Review output: The output from the management review shall include any decision and actions related to: a) Continual improvement opportunities; and b) Any needs for changes to the ISMS.	ISMC	Minutes of management review meeting
Half yearly progress of ISMS / Report of the ISMC / Information Security Plan Projections.	ISMC	
Records to be maintained for proceeding of Management Review Meeting. ISO is responsible for preparing and maintaining the minutes of Management Review Meeting.	ISO	Management Review Records

7.3.2. Review Meetings

Activity	Responsibility / Authority	Record Name & Number
Frequency of Management Review Meeting: Management (ISMC) Review Meeting to be conducted at least once in every six months.	ISO	
Purpose of Meeting: **To review the** XYZ-TS **- ISMS to** 1. Ensure its continuing suitability, adequacy and effectiveness.	ISMC	
2. Assess opportunities for improvement and the need for change to ISMS, Information Security Management System Manual and Procedures.		
Persons to participate in Meeting: 1. ISMC - Members 2. CDO	ISMC/ CDO	

XYZ | Confidential - External

CS5292 W6 · D05 · sanitised for teaching

8. Procedure for Nonconformity and Corrective Actions

8.1. Scope

- This procedure is applicable to corrective actions taken against nonconformities to the Information Security Management System in order to identify and eliminate the root cause, determine actions to eliminate so that their reoccurrence is prevented.
- This procedure is in line with the XYZ-TS Information Security Management System Manual (XYZTS-IS-MN-001) and adheres to below mentioned ISO/IEC 27001 Clause:
    - 10.2 – Nonconformity and Corrective Actions

8.2. Responsibility

- ISO
- ISMC
- ISMS Audit Team

8.3. Procedure

8.3.1. Corrective action

- This process defines the process of determining the root causes of any non-conformance or problem in the Management System and its implementation, and how the actions are taken in order to prevent recurrence of such deficiencies.
- In XYZ-TS, remedial actions are taken as soon as any nonconformity is identified, and thereafter the corrective actions are implemented via various processes to prevent the recurrence of nonconformities and problems related to Management System.

8.3.1.1. Identifying nonconformities

- Following are some of the sources used to identify the nonconformities:
    - Information security breaches / incidents;
    - Inputs or observations from internal or external audits;
    - Violation in implementation of management system with regard to documented ISMS; and
    - All identified nonconformities are appropriately recorded wherever necessary.

XYZ | Confidential - External

CS5292 W6 · D05 · sanitised for teaching

8.3.1.2. Determining the causes of nonconformities

- The causes for the nonconformities in the ISMS can be classified as under, but it is not limited to:
    - Insufficient training to users on the requirements of ISMS;
    - Not identifying the potential threats and vulnerabilities in time;
    - Not closing previously identified collective minor nonconformities in time, which may lead to major NCs;
    - Improper hardening of the system;
    - Effective change management is not in place; and
    - Not implementing timely patches recommended by the vendors.
- These causes can be identified by initiating systematic verification of documented controls against practices, etc.

8.3.1.3. Determining, evaluating and implementing the corrective actions needed

- Depending on the cause, possible corrective actions could include:
    - Changes in the IT security management;
    - Adapting IT security processes;
    - Taking staff-related measures, e.g. further training or measures aimed at promoting IT security awareness, or instituting disciplinary measures;
    - Physical Infrastructure measures, such as initiating structural changes in the buildings.
    - Taking technical measures, such as changes to the hardware and software or communications links and networks and use of new technology;
    - Seeking decisions from the responsible line manager;
    - Actions in response to new laws or regulations; and
    - Actions in response to changes in the IT baseline controls implemented.
- For all corrective actions that need to be acted upon, priority of decision shall be based upon the results of risk assessment and risk treatment.
- Implementation of corrective action can be done after identification of appropriate responsible person for directing and monitoring the corrective actions. Required resources shall be provided for the responsible person for directing and monitoring the corrective actions. If required, additional risk/s could be included in the relevant Risk Assessment and Treatment plan or if necessary, conduct additional brief risk analysis and risk assessment.
- During such review of corrective actions proposed, all relevant information captured should be documented and evaluated.

XYZ | Confidential - External

CS5292 W6 · D05 · sanitised for teaching

8.3.1.4. Recording the results of corrective actions taken

- The results on corrective actions taken should be documented and kept. This report may contain a technical description of the corrective actions proposed.
- Where serious problem exists, the ISMC will be involved in resolution, so that, far reaching decisions can be made promptly and quickly.

8.3.1.5. Review of Corrective actions proposed and implemented

- ISO shall review all corrective actions proposed and ensure that they are implemented, and nonconformities are closed within accepted time frame.
- Once, the non-conformities are closed to the satisfaction of ISO or auditor (wherever required), acknowledgment from either ISO or auditor is obtained on the report to ensure proper closure.

8.3.1.6. Identifying the potential nonconformities

- Potential problems can be identified by any method, including but not limited to five why analysis, what if analysis, risk analysis, or due diligence. These can be identified during risk analysis / assessment.
- Following are some of the other sources used to identify the potential problems or nonconformities.
    - Group of minor or similar incidents;
    - Reports of capacity, service availability and trend analysis;
    - Trend analysis reports on how the security procedures / processes are performing;
    - Trends of access logs (device or manual based) exception reports;
    - Incident monitoring data, list of known errors; and
    - Analysis of data gathered by internal or/and external audits, investigation from corrective actions, feedback from the identification process.

8.3.1.7. Evaluation of potential nonconformities

- After the potential nonconformities are identified, such nonconformities are recorded to assess their impact on the business processes and urgency for resolution.
- The potential risk of the event is determined by analysis of the cause data. Assistance for risk analysis and assessment can be sought from the ISO. The level of response is determined, and recommendations made.
- A decision to proceed with preventive measures will be taken based on likelihood, severity and frequency (refer RA methodology developed), of the potential event/incident.

CS5292 W6 · D05 · sanitised for teaching

8.3.1.8. Determining and implementing actions to prevent potential nonconformities

- An action plan is developed to prevent the potential nonconformities by responding to the situation and causes that trigger it. The action plan will include assigning the responsibilities and providing resources as well as monitoring progress and recording outcomes.

8.3.1.9. Recording results of actions taken

- Details of investigation and actions to prevent occurrence are kept by those involved. Reports back to the areas involved, and those charged with the responsibility for any actions are made to ensure a complete response to the event.
- For all significant potential events, the reports will be made available to discuss in the management review of ISMS.

8.3.1.10. Reviewing of effectiveness of the actions taken

- The effectiveness of decisions taken are monitored and reported to respective departments' heads by sending a copy to the ISO.
- Review of the preventive actions is undertaken to ensure that the changes have been effective, causes have been eliminated and potential problem has been prevented from occurring.
- A brief summary report on 'lessons learnt' and important/major actions taken are maintained with ISO.

9. Procedure for measurement of effectiveness of ISMS controls

9.1. Scope

- This procedure is in line with the XYZ-TS Information Security Management System Manual (XYZTS-IS-MN-003) and adheres to below mentioned ISO/IEC 27001:2022 Clauses:
    - 9.1 – Monitoring, measurement, analysis and evaluation
    - 10.1 – Continual improvement

9.2. Responsibility

- ISMC
- ISO

XYZ | Confidential - External

CS5292 W6 · D05 · sanitised for teaching

9.3. Procedure

9.3.1. Data collection

- XYZ-TS shall establish metrics that measure the outcome of its security policies, supporting procedures and technical controls (e.g.; number of security incidents that caused damage, compromise or loss due to non-existence or despite the existence of security controls).
- It is reasonable to assume that an incident or a nonconformance occurs owing to lack of implementation of a control or a group of controls (belonging to one or various security domains), a faulty implementation or noncompliance to a laid down process.
- Based on this assumption the effectiveness measurement of security controls at XYZ-TS are based on:
    - Information Security Objectives
    - Incidents: Repository of various information security incident reports available with the ISO
    - Audit: Results of periodic internal audits conducted
- ISO will maintain a XYZ-TS ***Information Security Dashboard*** (XYZ—TS-IS-RG-016) which will have matrices deriving from the above areas to determine the effectiveness of the ISMS.

9.3.2. Information Security Dashboard

9.3.2.1. Defining the Matrices

The ISO will carry out the following tasks in consultation with ISMC:

- Define the matrices attributable to a particular Annexure A control or a group of controls from the ISO/IEC 27001:2022 standard implemented at XYZ-TS.
- Define the measurement criteria for a particular control.
    - E.g. – for the 'Annexure A' control A.8.7 Protection Against Malware

XYZ | Confidential - External

CS5292 W6 · D05 · sanitised for teaching

- Measurement criteria: Virus mitigation

Attributes
A1. Total no. of virus incidents occurred.
A2. Total no. of viruses cleaned by Antivirus software or manually.

- Define the equation to produce an effectiveness result for each measurement criteria. For the above example the equation would be A2/A1.
- Minimum threshold will be set for the measurement criteria which indicates the acceptable level of control effectiveness.
- If a measurement criterion is not performed for a particular month, then the base measure of that measurement criteria shall be set to the default value mentioned in the ISMS Dashboard.

9.3.2.2. Measuring the Matrices

- XYZ-TS team quarterly collect the data required for the measurement criteria to calculate the effectiveness results.
- Possible scenarios for monitoring
- If the effectiveness results < threshold – monitor the control for the operability and take any actions required if applicable; and
- If the effectiveness results > threshold – control is operating as expected.

9.3.2.3. Reviewing the Matrices Results

- Results of the information security dashboard will be presented to ISO and any concerns derived from the information security dashboard will be taken up at the MRM/ISMC.
- In addition, level of threshold, new matrices or new measurement criteria will be decided at the MRM/ISMC.

10. Latest Version of This Document

- • The latest version of this document can be obtained from the CDO.

XYZ | Confidential - External

CS5292 W6 · D05 · sanitised for teaching

11. Key Roles & Responsibility

- The Chief Digital Officer (CDO) shall be accountable for the effective review, approval, communication, implementation, and adoption of the Mandatory ISMS procedure and all changes to the procedure.
- The Head of IT security shall own and be responsible for the accuracy and maintenance of this procedure as well as its effective communication and implementation.
- All IT employees across XYZ Holdings shall support the effective adoption and implementation of this Mandatory ISMS procedure.

12. Compliance and Disciplinary Action

- Systems and services provided by XYZ-TS are the property of XYZ-TS. This gives XYZ-TS the right to monitor all activities performed using these resources.
- Users shall maintain continued compliance with all XYZ-TS policies, procedures, guidelines, rules and administrative orders while using XYZ-TS systems, facilities and/or services.
- The Chief Digital Officer shall designate persons to perform periodic reviews and provide relevant feedback on the design and operating effectiveness of this procedure.
- Non-compliances to this procedure shall be recorded and responded through the Incident and Problem Management procedure.
- If XYZ-TS discovers or has good reason to suspect activities that do not comply with applicable laws or policies, activity logs or records may be retrieved and used/ presented as evidence for disciplinary action against the involved user.

13. Reference Documents

- XYZ-TS *Information Security Management System Policy* (XYZ-TS-IS-MN-001)
- *Information Security Dashboard*

XYZ | Confidential - External

CS5292 W6 · D05 · sanitised for teaching